OWASP · SEGURIDAD DE LA INFORMACIÓN · 2026-II

OWASP Amass

Descubrimiento de activos y mapeo de superficie de ataque

Del subdominio invisible al inventario priorizado: una práctica 100 % offline sobre un DNS autoritativo propio.



Michael Stiven Tabares Tobón
Ingeniería de Sistemas
Universidad de Antioquia
Seguridad de la Información — 2026-II

laboratorio: lab.local · 192.168.56.0/24

El problema

La superficie de ataque que nadie conoce

20+

subdominios descubiertos en una organización mediana

12

servicios públicos que se analizan y se pierden de vista

0

registros en el inventario oficial de la organización

Cada subdominio olvidado es una puerta que nadie vigila. El problema no es técnico: es que el inventario de activos se construye después del incidente, no antes.

OWASP Amass responde con una pregunta concreta: **¿qué activos existen realmente y cuáles de ellos importan?**

Definición

¿Qué es OWASP Amass?

Framework open source de OWASP para reconocimiento de activos y mapeo de superficie de ataque: combina OSINT, resolución DNS activa y correlación en un grafo de activos persistido.

01

No es solo un enumerador

Un subdominio aislado es ruido. Amass lo conecta con IPs, servicios, certificados y sus fuentes de descubrimiento.

02

Construye un grafo

Cada activo se modela como entidad y cada relación como arista. El resultado es un mapa, no una lista.

03

Persistencia y trazabilidad

Cada hallazgo guarda su procedencia, TTL y confianza. Se puede comparar la superficie entre fechas.

`dig` responde una pregunta. `amass enum` construye el mapa completo de lo que esa respuesta implica.

Estrategias de reconocimiento

Dos estrategias: pasivo y activo

PASIVO

No toca el objetivo

Consulta	Fuentes OSINT: Certificate Transparency, DNS histórico, motores de búsqueda
Tráfico al objetivo	Ninguno
Detecta	Nombres publicados, certificados emitidos, dominios históricos
Límite	Lo que otros ya publicaron
Riesgo	Muy bajo

ACTIVO

Interroga la infraestructura

Consulta	El DNS autoritativo y los servicios del objetivo
Tráfico al objetivo	Consultas DNS + comprobación de puertos
Detecta	Lo que existe ahora, incluidos hosts sin índice público
Límite	El alcance y los puertos que se autoricen
Riesgo	Medio — requiere autorización expresa

En este laboratorio usaremos el modo activo contra un DNS propio. **Un ataque a un DNS real sin autorización no es unethical: es un delito.**

Cómo funciona por dentro

Arquitectura: del dato al grafo

1

Fuentes

OSINT, DNS autoritativo, listas de palabras

2

Motor

Plugins que consultan, validan y correlacionan

3

Base de datos

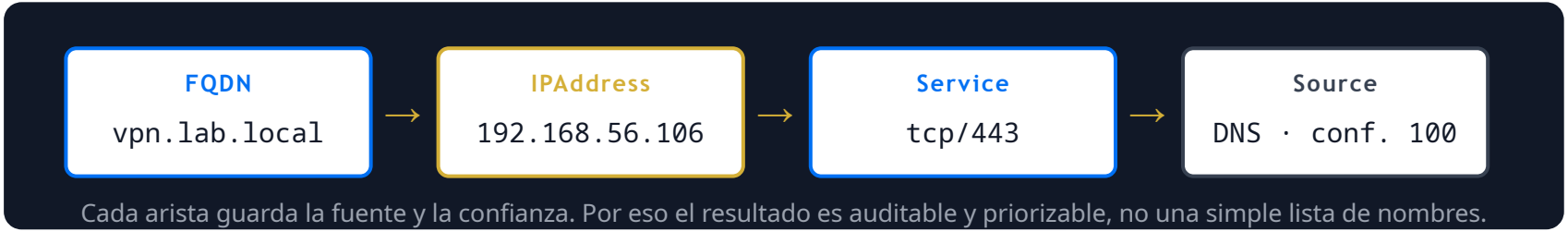
SQLite local: entidades, aristas y procedencia

4

Salida

subs, track, viz y export JSON

Lo que queda almacenado (Open Asset Model)



Cada arista guarda la fuente y la confianza. Por eso el resultado es auditable y priorizable, no una simple lista de nombres.

Persistencia

La base de datos: memoria del laboratorio

¿Para qué sirve la base de datos de Amass?

Persistir

Cada ejecución queda guardada. Se puede comparar la superficie de ataque de hoy contra la de la semana pasada y detectar qué cambió.

Correlacionar

Un mismo activo encontrado por tres fuentes se guarda una sola vez, anotando las tres procedencias. Se elimina el ruido.

Priorizar

Almacena TTL, confianza y origen de cada dato, para distinguir un hallazgo sólido de una simple pista.

Backends disponibles

SQLite — USAMOS ESTE

Se crea solo, sin configurar. Ideal para el laboratorio y para auditorías puntuales.

PostgreSQL — PRODUCCIÓN

Repositorio centralizado para equipos que necesitan histórico compartido y multiusuario.

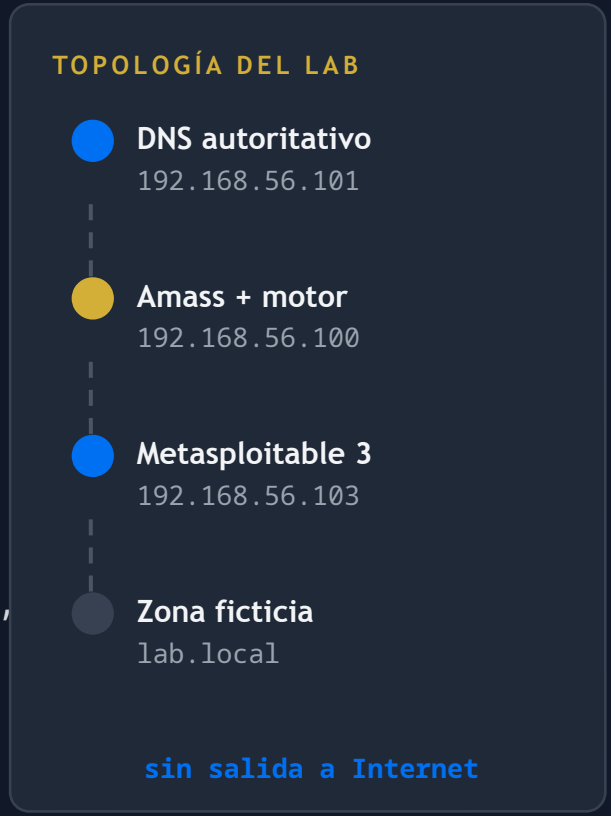
Neo4j — AVANZADO

Consultas de grafo-native sobre relaciones de primer y segundo nivel.

02

Manos a la obra

Laboratorio 100 % offline: un DNS autoritativo propio, zona ficticia y 17 minutos de práctica real.



Práctica · Paso 0

Primero: demostrar que el laboratorio está aislado

atacante@lab: ~

```
# 1. Internet debe estar BLOQUEADO
$ curl -s --max-time 5 https://owasp.org
(sin salida — DROP por iptables)

# 2. El DNS del laboratorio responde
$ dig @192.168.56.101 dev.lab.local A
dev.lab.local.   300  IN  A  192.168.56.103

# 3. Versión de Amass
$ docker run --rm amass:latest -version
v5.1.3
```

Por qué importa

- Amass v5 usa 53 resolvers públicos embebidos en el código.
- Sin bloqueo de red, el motor sale a Internet aunque el config diga lo contrario.
- La redirección DNAT + SNAT los envía al DNS del laboratorio.

Lo que vemos en la terminal

Amass v5 no tiene la opción -src ni -o en el subcomando enum. Los resultados se consultan después con amass subs, que lee la base de datos SQLite compartida.

Práctica · Pasos 1 y 2

Enumeración activa y fuerza bruta controlada

```
atacante@lab: ~/amass-lab
$ amass enum -active \
      -d lab.local -p 80,443 \
      -nf wordlists/seeds.txt

29 / 30 [======>      ] 96.67% ? p/s25

$ amass subs -names -d lab.local -ip
vpn.lab.local        192.168.56.106
old.lab.local        192.168.56.110
lab.local            192.168.56.103
mail.lab.local       192.168.56.103
ns1.lab.local        192.168.56.101
```

Flags que importan

`-active`	Resolución DNS y comprobación de servicios
`-d`	Dominio objetivo
`-p`	Puertos: muro de seguridad del ejercicio
`-nf`	Nombres ya conocidos que se validan contra el DNS
`-timeout`	Minutos sin progreso antes de terminar

La fuerza bruta no adivina: pregunta al DNS. En la lista de 13 semillas, 11 existen en la zona y 2 no. El DNS autoritativo es quien decide — y Amass descarta lo que no existe.

Práctica · Paso 3

Del hallazgo al riesgo: el valor real de Amass

Activo	Severidad	Por qué importa
`vpn.lab.local`	CRÍTICO	Acceso remoto a toda la organización desde un único activo
`dev / staging / qa`	ALTO	Entornos de preproducción con controles más débiles que producción
`jenkins / gitlab`	ALTO	Cadena de suministro: acceso al código y a los pipelines de despliegue
`admin.lab.local`	ALTO	Panel de administración expuesto a Internet
`old.lab.local`	MEDIO	Activo residual: probable deuda técnica sin actualizar
`www / mail`	BAJO	Activos públicos esperados, sin señal de riesgo por sí solos

La herramienta no prioriza: **entrega el inventario con su procedencia.** La priorización exige contexto: si 192.168.56.103 es producción o un laboratorio de pruebas, el mismo hallazgo cambia de severidad. Eso lo decide el equipo, no el script.

Cierre

Tres ideas para llevarse

01

Amass es un grafo, no una lista

Conecta nombre, IP, servicio y procedencia. El valor está en la relación entre los datos, no en el dato aislado.

02

Pasivo y activo responden preguntas distintas

El pasivo no toca el objetivo; el activo lo interroga. Ambos son legítimos, pero exigen autorización y alcance distintos.

03

El límite real es el ethical scope

La herramienta se automatiza; la responsabilidad no. Entender el alcance es más difícil que dominar los comandos.

Todo lo demostrado se ejecutó en máquinas virtuales locales.
Ni una sola consulta salió a Internet.

¿Preguntas?

Michael Stiven Tabares Tobón · Ingeniería de Sistemas · Universidad de Antioquia · Seguridad de la Información 2026-II

owasp.org/projects/amass